

Cybersecurity & Blockchain

KGSP Enrichment [Week 3 & 4 – 2026]





Mudassar Aslam

(FHEA, PhD Cybersecurity)

Associate Professor of Cybersecurity & Program Director,
School of Engineering, Computing and Mathematics,
Oxford Brookes University,
Oxford, United Kingdom.
maslam@brookes.ac.uk

www.mudassir.info



Day 07 – Pentesting



جامعة الملك عبد الله
للعلوم والتقنية
King Abdullah University of
Science and Technology



Hacking and Pentesting



جامعة الملك عبد الله
للعلوم والتقنية
King Abdullah University of
Science and Technology



Can Hacking be Ethical?

- Why to hack own systems?
 - Measures like **vulnerability testing** and **security audits** are not enough
 - Attackers use creativity and think 'out-of-the-box' to hack-in
- Goal of the ethical hacker
 - help the organization take pre-emptive measures against malicious attacks by attacking the system himself; all the while staying **within legal limits**.
- Ethical Hacker
 - an individual who is usually employed with the organization and who can be trusted to undertake an attempt to penetrate networks and/or computer systems using the same methods as a Hacker.
- Certified Ethical Hacker
 - skilled professional who understands and knows how to look for the weaknesses and vulnerabilities in target systems and uses the same knowledge and tools as a malicious hacker.

What is Penetration Testing?

- A penetration test (or pentest) is an ethically-driven attempt to test and analyse the security defences of **computer systems**, **networks**, and **applications** to protect assets and information.
- Uses same **tools**, **techniques**, and **methodologies** as malicious attackers
- **Authorized** security audit agreed upon by system owners - Similar to a security audit but more hands-on and practical
- **Legally** protected when conducted within agreed scope
- The Cyber Attack Reality:
 - Over 2,200 cyber attacks occur every day globally [Live Map: [Kaspersky](#), [Checkpoint](#), [CISCO](#)]
 - That equals 1 attack every 39 seconds
 - Penetration testing helps organizations defend against these threats before they happen

Why Penetration Testing Matters

▪ Relevance in Modern World:

- Cybersecurity is relevant to everyone - from individual email protection to enterprise networks
- Organizations need to protect both devices and data from damage, theft, and unauthorized access
- Critical for businesses, governments, and essential infrastructure

▪ Benefits of Penetration Testing:

- Identifies vulnerabilities before attackers do
- Validates effectiveness of existing security controls
- Tests incident response procedures
- Demonstrates compliance with security standards
- Reduces overall risk and breach probability
- Provides actionable recommendations for improvement

Penetration testing is a proactive security measure that prevents costly breaches.

Types of Hackers (By Ethics & Legality) - I

♥ White Hat Hackers

- "Good people" who remain within the law
- Use skills to benefit others and improve security
- Example: Penetration testers performing **authorized engagements**
- Work with explicit permission and within **scope**
- only "**CHECK** approved companies can conduct authorised penetration tests of public sector and CNI systems and networks." (NCSC).



Types of Hackers (By Ethics & Legality) - II



♥ Grey Hat Hackers

- Use skills to benefit others BUT don't always respect law or ethical standards
- Example: Taking down a scamming website without authorization
- Operate in legal grey area—may help but break rules doing it
- Not recommended or legally protected



Types of Hackers (By Ethics & Legality) - III

♥ Black Hat Hackers

- **Criminals** seeking to damage organizations or gain financial benefit
- Operate **illegally** for personal profit
- Example: Ransomware authors, data thieves, fraudsters
- Subject to legal prosecution and imprisonment

A pentester must ALWAYS be a White Hat, conducting authorized work within legal boundaries.



Legal Authorization - Rules of Engagement

- The Rules of Engagement (RoE) Document: A formal agreement created at the initial stages of penetration testing engagement that defines:

1. Permission Section

- Gives explicit permission for engagement to be carried out
- Legally protects individuals and organizations for activities performed
- Must be signed by authorized representatives

2. Test Scope Section (anything outside agreed scope = unauthorized and illegal)

- Specifies exact targets to be tested (e.g., specific servers, applications, networks)
- Defines what IS and IS NOT in scope
- Prevents accidental or intentional testing of off-limit systems
- Example: "Test only Production Web Server #1, NOT the Database Server"

3. Rules Section

- Defines which techniques ARE permitted (e.g., SQL injection testing)
 - Defines which techniques are PROHIBITED (e.g., denial of service attacks)
 - Specifies testing windows (e.g., only weekends, 2am-6am)
 - Clarifies data handling and escalation procedures
- Best Practice: [SANS Institute RoE templates](#)



Penetration Testing Methodology

- What is a Methodology?
 - The systematic steps and approach a penetration tester takes during an engagement.
 - Since no two penetration tests are identical, methodology must be tailored to the situation.
- General Principle:
 - Use methodologies relevant to your situation
 - A web app testing approach differs from network penetration testing
 - One methodology does NOT fit all scenarios
- The Five Common Stages (Present in All Methodologies):
 - Phase 1 - Information Gathering (Reconnaissance)
 - Phase 2 - Enumeration & Scanning
 - Phase 3 - Exploitation
 - Phase 4 - Privilege Escalation
 - Phase 5 - Post-Exploitation

1. Information Gathering (Reconnaissance)

- Collect as much publicly accessible information about the target organization as possible WITHOUT accessing any systems.
 - Company employees, organizational structure, contact information
 - Domain and website information
 - IP address ranges and network information
 - Technology stack and software versions
 - Public company documents, press releases, social media
 - Email formats and naming conventions
 - Historical data from WHOIS records and archives
- Passive technique
 - Google dorking (advanced search techniques)
 - Social media research
 - WHOIS lookups
 - DNS queries
 - Web scraping public data
 - News articles and company announcements
- Significance
 - Larger attack surface = better understanding of target
 - Helps identify potential entry points
 - Passive = no detection risk
 - Foundation for all subsequent phases

Information gathering is detective work - learn everything about the target without touching any systems.



2. Enumeration & Scanning

- Actively discover and map services, applications, and systems running on target infrastructure.
 - Active hosts and their IP addresses
 - Open ports and services running
 - Operating systems and versions
 - Application names and versions
 - Firewall/security device presence
 - Virtual hosts and subdomains
 - Usernames and account information
- Important Difference from Info Gathering:
 - Information Gathering = PASSIVE (no traffic sent to target)
 - Enumeration/Scanning = ACTIVE (sends traffic to target, CAN be detected)

Note: Scanning may trigger IDS/IPS alerts - important for realistic testing

•Tools Used

- Port scanners (Nmap)
- Vulnerability scanners (Nessus, OpenVAS)
- Web application scanners (Burp Suite)
- DNS enumeration tools

•Key Techniques:

- Port scanning (TCP/UDP)
- Service version detection
- Operating system fingerprinting
- Web server enumeration
- Subdomain discovery
- Active directory enumeration



Phase 3 - Exploitation

- Identify and leverage **exploitable vulnerabilities** from previous scanning to gain unauthorized access or control of systems.
- Develop or select appropriate **exploit code** and execute against the target systems
- Gains **initial access** or foothold on system
 - > Document successful exploitation
- Types of Exploitation
 - Exploiting known vulnerabilities (CVEs)
 - Using public exploit code from databases
 - Custom exploit development for specific vulnerabilities
 - Exploiting application logic flaws
- Social engineering attacks
 - Phishing campaigns
- Common Targets:
 - Unpatched systems with known vulnerabilities
 - Weak authentication mechanisms
 - Configuration errors
 - Application flaws (SQL injection, XSS, buffer overflows)
 - Zero-day vulnerabilities (if discovered)
- Success Indicators:
 - Gained shell access to system
 - Compromised user account

Phase 4 - Privilege Escalation

- Expand access and permissions after gaining initial foothold on a system, that is, increasing your access level from limited user to higher privileges (e.g., administrator).
- Initial access often has limited permissions -> Administrative access enables:
 - Installing backdoors for persistence
 - Accessing sensitive data
 - Modifying system configuration
 - Accessing other systems on network
 - Covering tracks
- Common Methods:
 - Exploiting local vulnerabilities
 - Misconfigured sudo/Windows permissions
 - Weak passwords or password reuse
 - Kernel exploits
 - Service vulnerabilities running as admin

Vertical Privilege Escalation

- Privilege Elevation
- Escalate from lower permission group to higher permission group
- Example: Regular user → Administrator/Root
- Most common and valuable
- Gives near-complete system control

Horizontal Privilege Escalation

- Lateral Movement
- Access another account within the same permission group
- Example: User A → User B (both are standard users)
- Useful for accessing different resources or user data
- Sets up lateral movement across network

Phase 5 - Post-Exploitation

▪ Maintaining Access (Persistence)

- Install backdoors for future access
- Create new user accounts
- Establish reverse shells
- Modify system startup files
- Install rootkits or persistence mechanisms
- Document how to maintain access

▪ Gathering Intelligence

- Extract sensitive data (passwords, keys, documents)
- Identify additional systems to target
- Map network architecture and trust relationships
- Locate databases and file servers
- Gather business intelligence
- Identify critical systems and data

• Demonstrating Impact

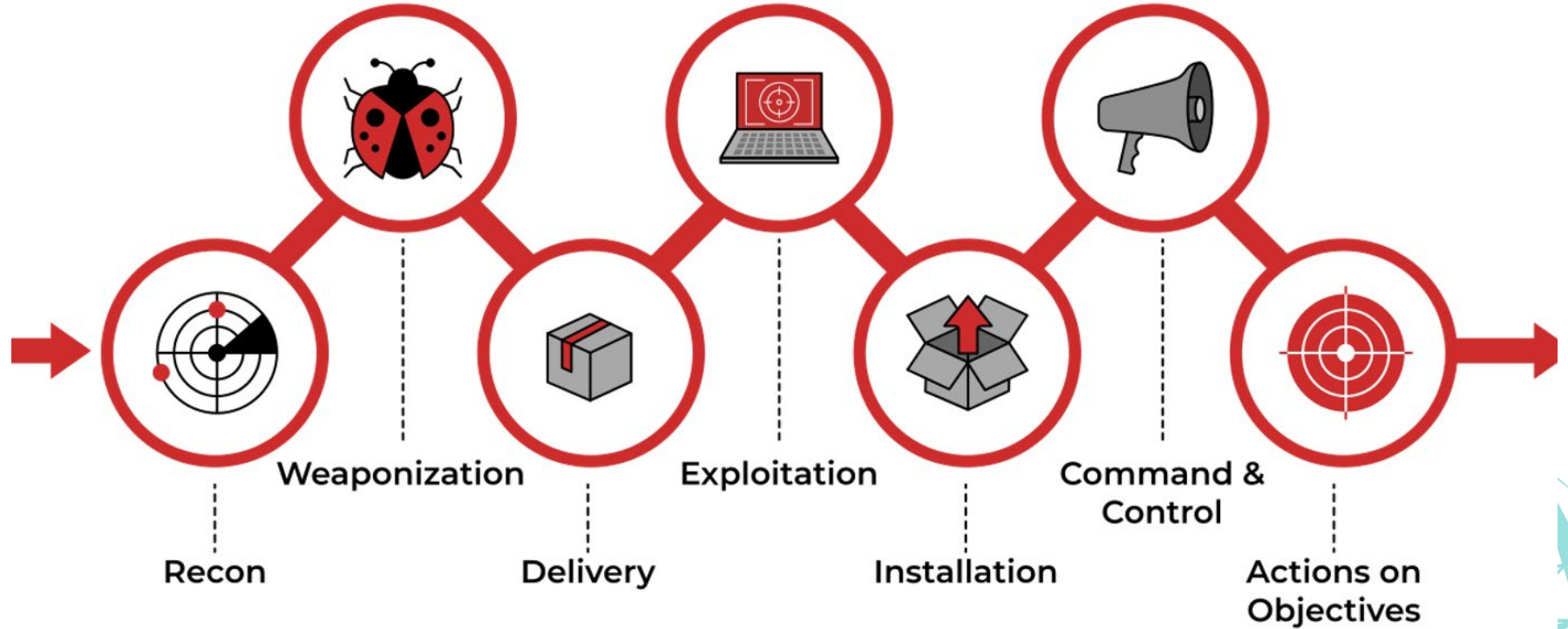
- Show what data was accessed
- Document business impact of compromise
- Demonstrate lateral movement capabilities
- Show persistence mechanisms
- Illustrate data exfiltration possibilities

• Cleaning Up & Reporting

- Remove evidence of compromise (as agreed)
- Restore systems to pre-test state
- Document all activities performed
- Prepare comprehensive penetration test report
- Present findings to client

Post-exploitation shows TRUE impact - not just that a vulnerability exists, but what an attacker could do with it.

Cyber Kill Chain



Casino Fish Tank hack

- 1. Reconnaissance:** The attackers scanned the casino's public IP address space and network footprint. **Scanning not detected**
- 2. Weaponization:** The threat actors identified specific vulnerabilities in the aquarium device's software, such as a security flaw, an open port, or default credentials. They paired this vulnerability with code or scripts designed to exploit the IoT device and grant them remote command execution. **No update or patch applied.**
- 3. Delivery:** The attackers transmitted their exploit package directly over the internet to the fish tank monitor. **No perimeter firewall blocked or access control implemented.**
- 4. Exploitation:** The malicious code executed on the fish tank thermometer, taking advantage of the unpatched security flaw or default access configuration. **No host based detection available.**
- 5. Installation:** The attackers established a persistent presence on the device or pivoted immediately onto the wider corporate network. **Network not properly segmented.**
- 6. Command & Control (C2):** The compromised internal systems established an outbound communications channel back to infrastructure controlled by the attackers. The fish tank monitor began exhibiting unusual outbound traffic patterns, communicating over the network to a rare external destination server located in Finland. **Exfiltration not detected by SIEM.**
- 7. Actions on Objectives:** The ultimate goal of the attack was realized: mass data theft of approximately 10 gigabytes of data

Practical: Pentesting Demo



جامعة الملك عبد الله
للعلوم والتقنية
King Abdullah University of
Science and Technology



جامعة الملك عبد الله
للعلوم والتقنية
King Abdullah University of
Science and Technology